

Abdelmalek Essaadi University
Faculty of Sciences and Techniques of Tangier
Master's in IT Security and Big Data

Design and Implementation of a Segmented Privileged Access Gateway

Network Segmentation, Policy Enforcement, and Privileged Session Brokering

Author:
Anas Ahrarache

Personal Security Lab Project – Systems and Network Security
Tools used: GNS3, VMware Workstation, FortiGate, JumpServer

Contents

1	Introduction and Context	2
1.1	Choice of Broker Tool	2
1.2	Scope of the Project	2
2	Project Objectives	3
3	Lab Architecture	4
3.1	Virtualization Environment	4
3.2	Logical Architecture Diagram	4
3.3	Technical Topology in GNS3	5
3.4	Addressing Plan	5
4	Network Segmentation and Firewall Policies	6
4.1	Initial State: Implicit Deny by Default	6
4.2	Validating the Explicit Enforcement Principle	6
4.3	Final Policies	7
5	Deployment and Configuration of the PAM Broker (JumpServer)	8
5.1	Installation	8
5.2	Registering the Target Server (Asset)	9
5.3	Creating the Technical Account	9
5.4	Separation of Duties: Creating an Operational User	10
5.5	Access Authorization	11
6	Connection Test and Session Brokering	12
6.1	Functional Flow of Access Brokering	12
6.2	Connecting to the Operational Workbench	13
6.3	Establishing the SSH Session	13
7	Audit, Traceability, and Session Recording	15
7.1	Login Logs	15
7.2	Operation Logs	16
7.3	Session Command Recording	16
7.4	Replay of the Recorded Session	17
8	Project Scope and Paths for Evolution	18
8.1	Potential Reinforcement: Firewall Administration	18
8.2	Potential Reinforcement: Resilience Against a Compromised Workstation	18
8.3	Extension Toward a Complete Zero Trust Architecture	18
8.4	Substitution of Wallix Bastion with JumpServer	19
8.5	Summary of Identified Improvements	19
9	Conclusion	20

1. Introduction and Context

During my internship in a Security Operations Center (SOC), I worked daily with perimeter security and privileged access management solutions, in particular FortiGate, Forcepoint, and Wallix Bastion. This direct exposure to Privileged Access Management (PAM) tools in a professional environment motivated me to build, in parallel, a personal lab reproducing the core principles of this type of architecture.

This project demonstrates, in a practical and fully verified manner, that it is possible to enforce a single, controlled entry point for any administrative access to a sensitive server, by combining:

- strict network segmentation enforced by a next-generation firewall (FortiGate),
- a privileged access broker (JumpServer) responsible for credential management and session recording.

1.1 Choice of Broker Tool

The project was initially planned around Wallix Bastion, the tool used during my internship. As the vendor's commercial validation process for an evaluation license could not be completed within the project timeline, I chose to build the lab with **JumpServer**, an open-source PAM solution built on the same core architectural principles: password vaulting, session brokering, recording, and granular authorization. The network architecture and the policies designed are independent of the specific PAM product deployed, and could be reproduced identically with Wallix Bastion.

1.2 Scope of the Project

This project rigorously applies several principles that constitute the *Zero Trust* approach, specifically at the level of privileged access:

- deny-by-default between network zones,
- explicit and tested policy enforcement,
- privileged access control, with strict separation between authorization and possession of credentials,
- network segmentation into isolated zones.

It deliberately differs from a full, organization-wide Zero Trust architecture (centralized identity provider, continuous verification, endpoint posture control), whose broader scope is discussed in Chapter 8.

2. Project Objectives

1. Design a network architecture segmented into isolated zones (administration, broker, server), with no direct route possible between the administration zone and the server zone.
2. Configure a FortiGate firewall as the single enforcement point (*choke point*) between these zones.
3. Demonstrate, through real and documented tests, that direct access between the administration zone and the server is blocked by default.
4. Deploy a privileged access broker (JumpServer) in a dedicated network zone.
5. Configure firewall policies allowing only the legitimate flows: administration to broker, broker to server.
6. Register the target server's authentication information in the broker, so that the operational user never has knowledge of the real password.
7. Establish an SSH connection to the server through the broker and verify that the session is fully recorded (commands, video playback).
8. Carry out an in-depth analysis of the security scope covered by the architecture and identify its next steps of evolution.

3. Lab Architecture

3.1 Virtualization Environment

Tool	Role
GNS3	Network topology orchestration and node interconnection
VMware Workstation Pro	Hypervisor hosting all virtual machines
FortiGate (VM64)	Firewall enforcing segmentation and access policies
Ubuntu Desktop	Administration workstation (AdminVM)
Ubuntu Server	Protected target server (Server_VM) and PAM broker (Broker_VM)
JumpServer (v4.10)	Privileged Access Management (PAM) solution

Table 3.1: Lab components

3.2 Logical Architecture Diagram

The diagram below presents the complete logical architecture of the lab: the three isolated network zones, the FortiGate firewall as the single point of passage, and the position of the PAM broker between the administrator and the protected server.

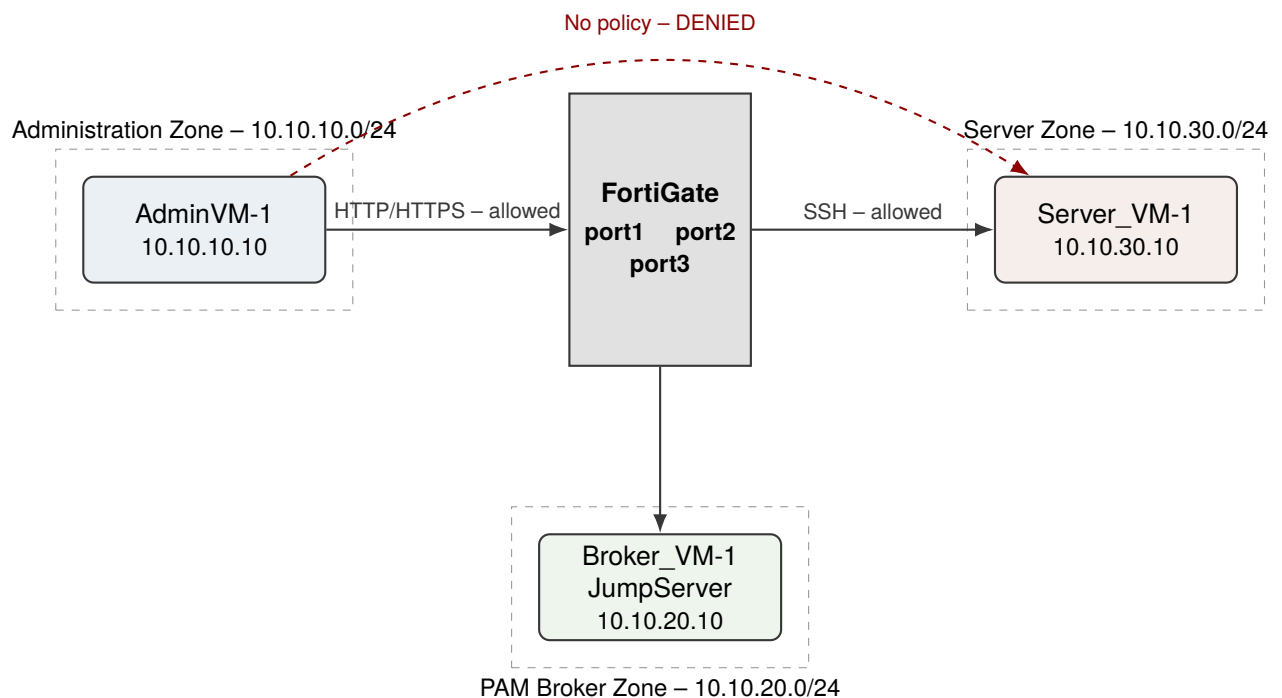


Figure 3.1: Logical architecture: FortiGate as the single point of passage between the three zones. No direct path exists between administration and the server.

This diagram highlights the central element of the architecture: the only existing path between the administration zone and the server necessarily passes through the PAM broker. The direct route, shown as a dashed line, corresponds to no firewall policy and is therefore systematically denied.

3.3 Technical Topology in GNS3

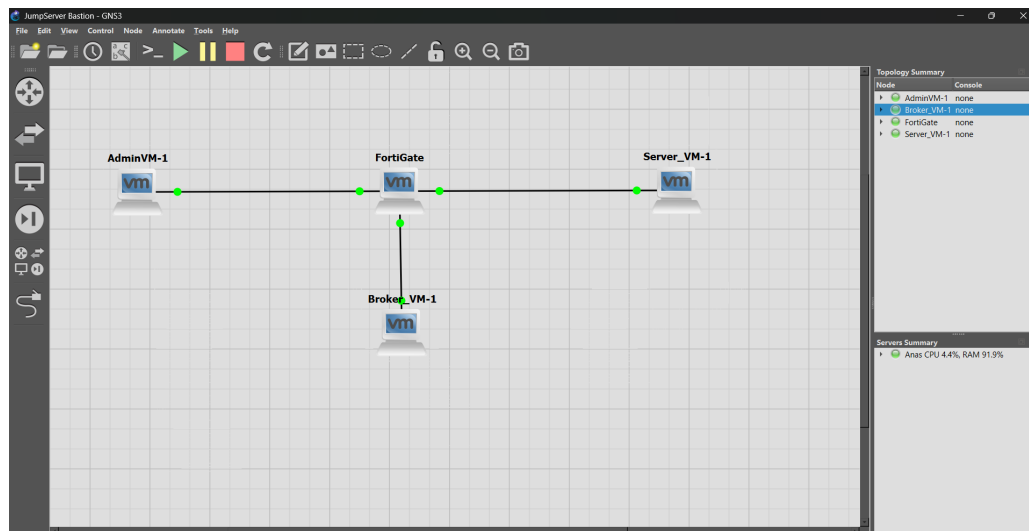


Figure 3.2: Lab topology in GNS3: AdminVM-1, FortiGate, Broker_VM-1, and Server_VM-1

3.4 Addressing Plan

Zone	FortiGate Interface	Subnet	Machine
Administration	port1	10.10.10.0/24	AdminVM-1 (10.10.10.10)
PAM Broker	port3	10.10.20.0/24	Broker_VM-1 – JumpServer (10.10.20.10)
Server	port2	10.10.30.0/24	Server_VM-1 (10.10.30.10)

Table 3.2: Addressing plan for the lab's three zones

This division into three distinct zones allows the firewall to have an independent observation point for each of the three actors (administrator, broker, server), and to apply distinct policies to each flow, rather than relying on per-host rules within a single segment.

4. Network Segmentation and Firewall Policies

4.1 Initial State: Implicit Deny by Default

FortiGate applies an implicit deny policy by default between any pair of interfaces for which no explicit policy has been defined. A verification confirmed that no traffic was allowed between zones before any rule was created, establishing a secure baseline.

4.2 Validating the Explicit Enforcement Principle

To prove that the firewall genuinely enforces the configured rules, rather than an implicit allowance, a temporary test was carried out: a direct authorization policy between port1 (administration) and port2 (server) was created, tested successfully, and then removed.

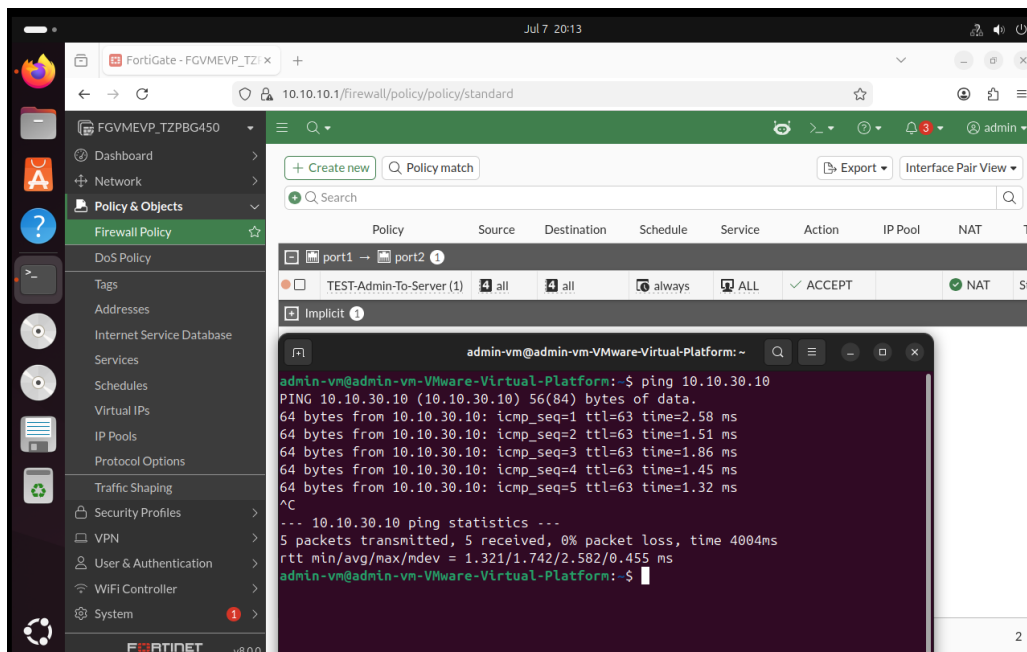


Figure 4.1: Temporary validation: explicit port1-to-port2 authorization, tested then revoked

This test confirmed three essential points:

- in the absence of a policy, communication between administration and the server consistently fails (0 packets received);
- as soon as an explicit authorization policy is added, communication succeeds immediately (0% packet loss);
- after the policy is removed, communication fails again, confirming that the firewall's behavior is entirely governed by the active configuration.

4.3 Final Policies

Policy	Source → Destination	Service	Action
Admin-To-Broker	port1 → port3	HTTP / HTTPS	ACCEPT
Broker-To-Server	port3 → port2	SSH	ACCEPT
(implicit)	port1 → port2	–	DENY

Table 4.1: Firewall policies applied in the final architecture

No policy was created between port1 (administration) and port2 (server). This deliberate absence of a rule is precisely what guarantees that the only possible path between the administrator and the server necessarily passes through the JumpServer broker. Services were also restricted to the strict minimum required (HTTP/HTTPS for the broker’s web interface, SSH for the broker’s connection to the server), rather than allowing all services, applying the principle of least privilege at the service level in addition to zone-based segmentation.

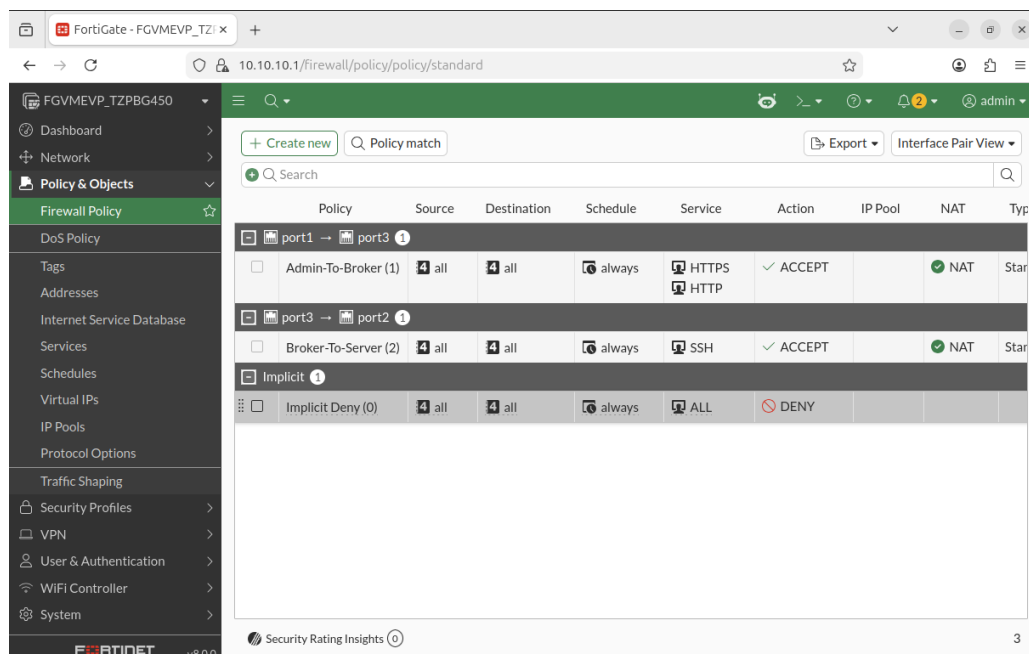


Figure 4.2: Final firewall policies in the FortiGate interface

5. Deployment and Configuration of the PAM Broker (JumpServer)

5.1 Installation

JumpServer was deployed on a dedicated Ubuntu Server virtual machine (Broker_VM), using the official Docker-based installation script:

```
cd /opt
curl -sSL https://github.com/jumpserver/jumpserver/releases/latest/download/quick_start.sh |
sudo bash
```

Since installation requires internet access to download the Docker images, the machine was temporarily attached to a NAT network during installation, before being reintegrated into the isolated 10.10.20.0/24 segment corresponding to its final zone in the topology.

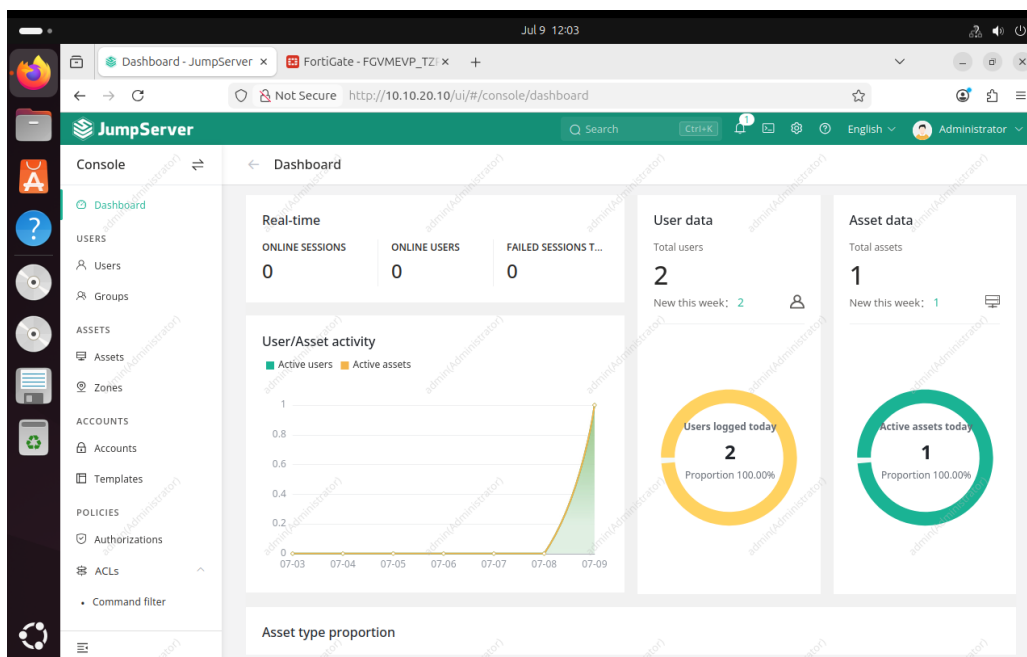


Figure 5.1: Dashboard of the deployed JumpServer instance

5.2 Registering the Target Server (Asset)

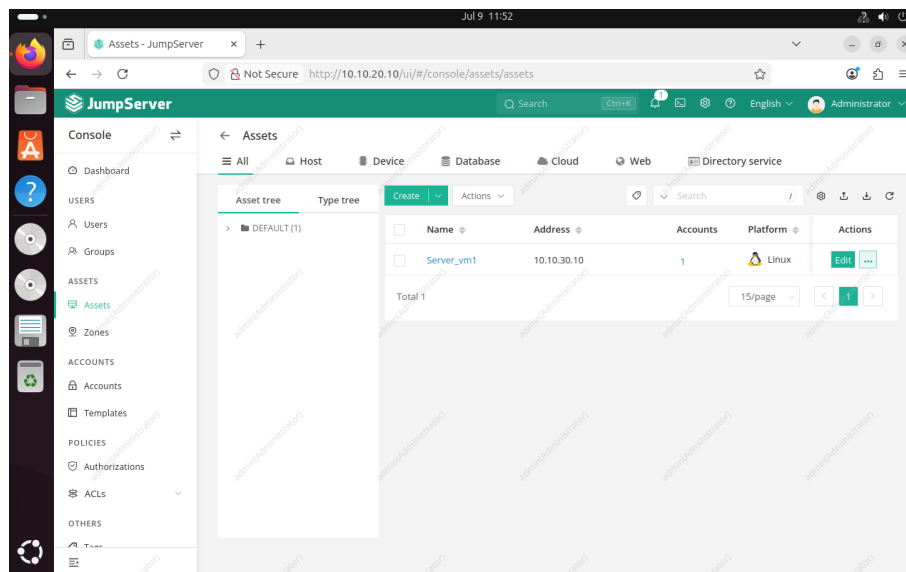


Figure 5.2: Registration of Server_VM1 as an Asset in JumpServer

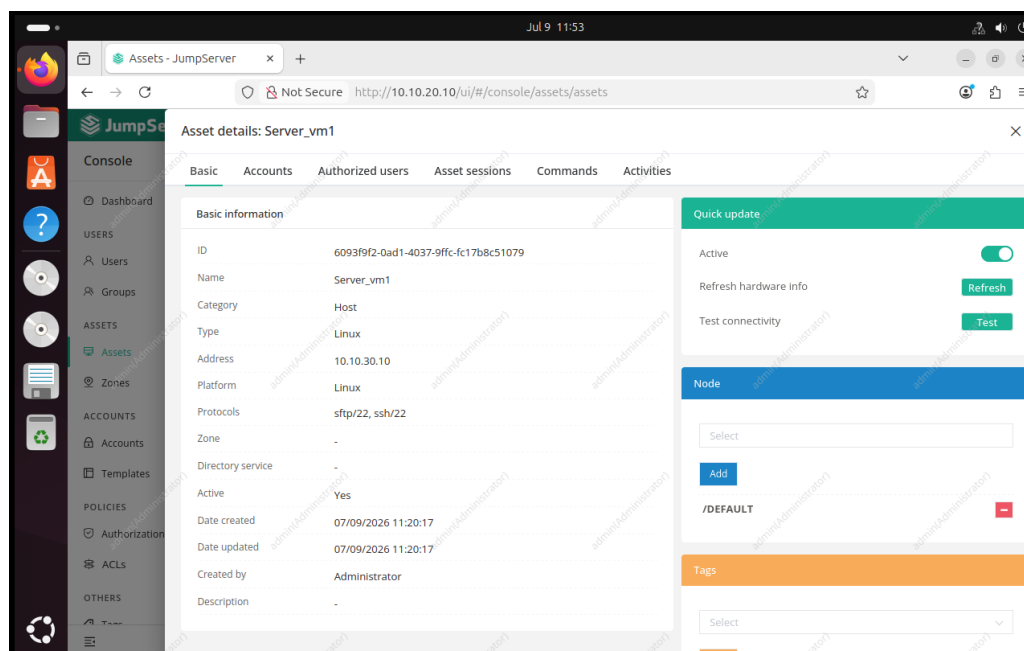


Figure 5.3: Details of the Server_VM1 Asset: protocols, zone, status

5.3 Creating the Technical Account

A technical account linked to this Asset was created, containing the server's real SSH credentials. This account constitutes the password vault: its secret is never communicated directly to the end user.

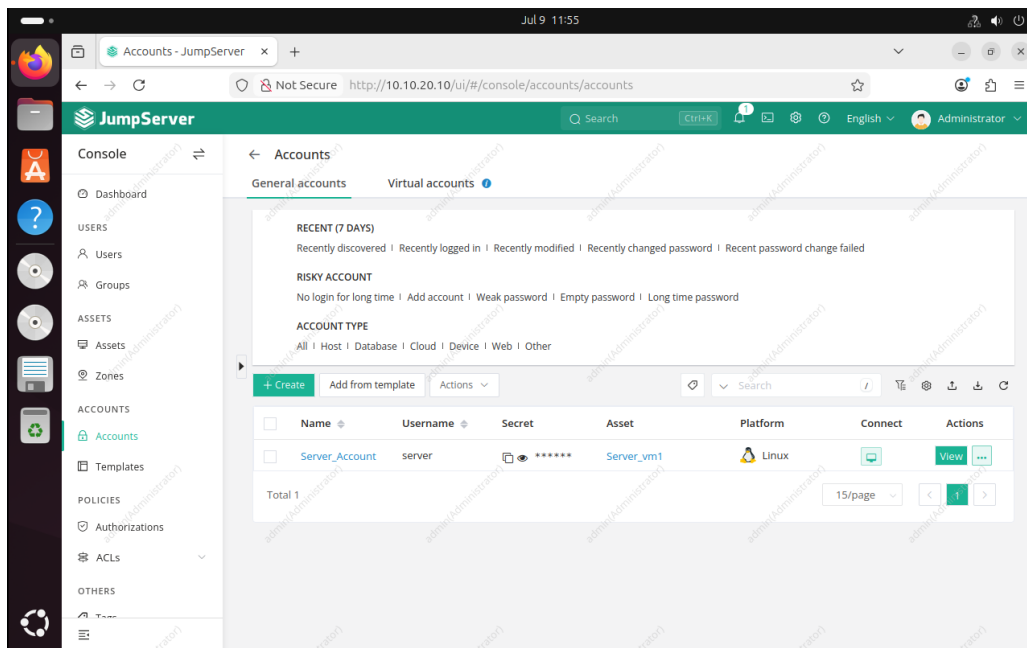


Figure 5.4: Technical account `Server_Account` linked to the `Server_VM1` Asset

5.4 Separation of Duties: Creating an Operational User

Rather than using JumpServer's super-administrator account to perform connections to the server, a separate operational user, `Operator1`, was created, applying the principle of separation of duties: the account configuring the PAM system (Administrator) is distinct from the account authorized to use it on a daily basis (`Operator1`).

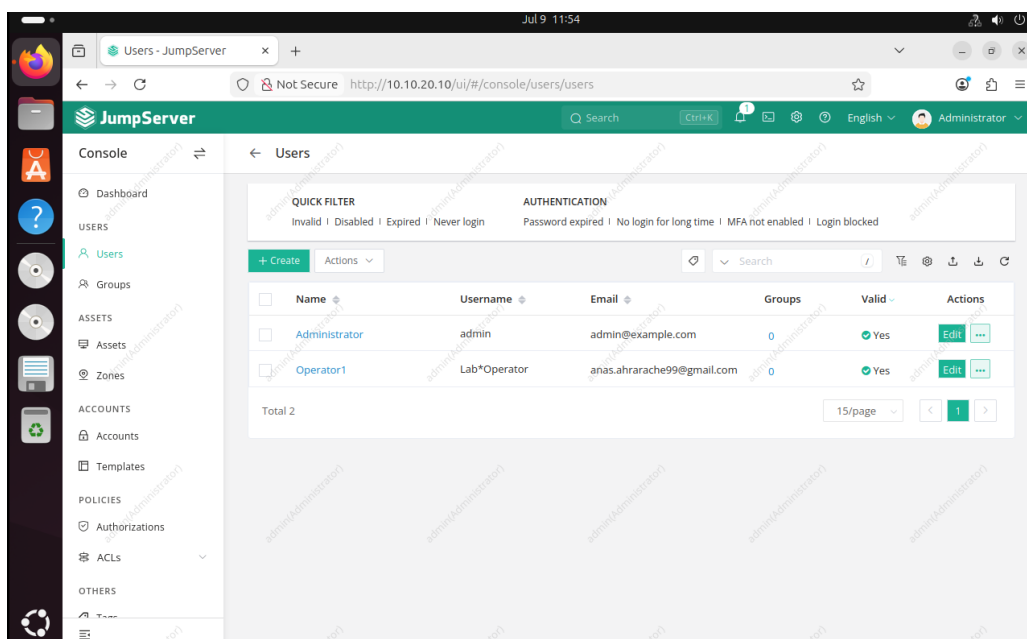


Figure 5.5: JumpServer users: Administrator and Operator1

5.5 Access Authorization

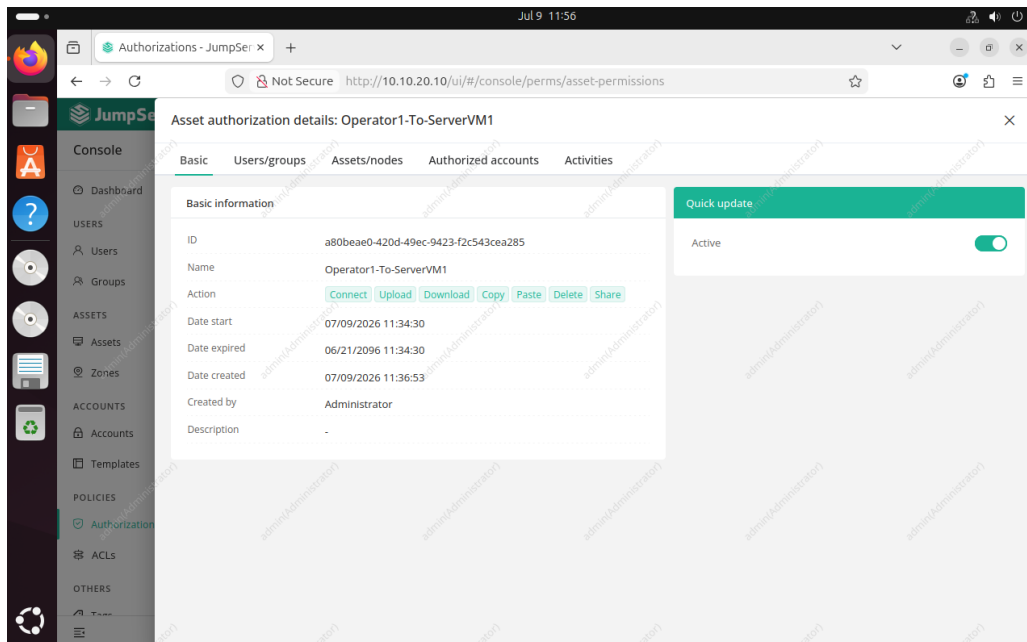


Figure 5.6: Authorization rule Operator1-To-ServerVM1

6. Connection Test and Session Brokering

6.1 Functional Flow of Access Brokering

The diagram below illustrates the complete sequence of a privileged connection, from the operator's authentication through to session recording, including the separation between authorization and possession of the secret.

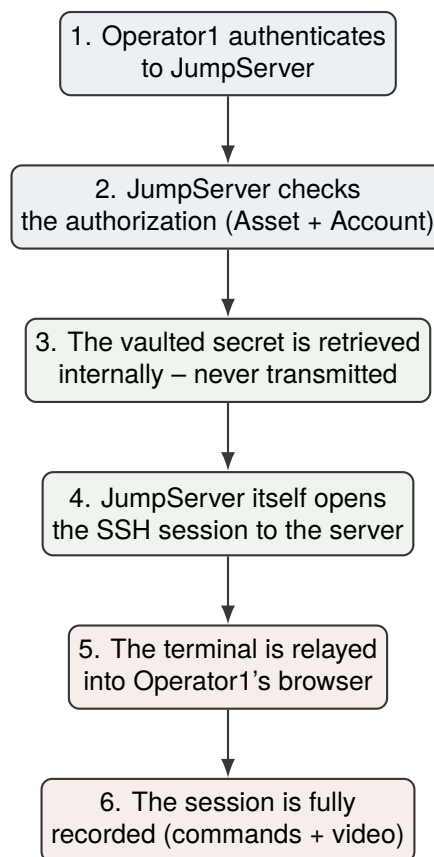


Figure 6.1: Functional sequence of privileged access brokering via JumpServer

6.2 Connecting to the Operational Workbench

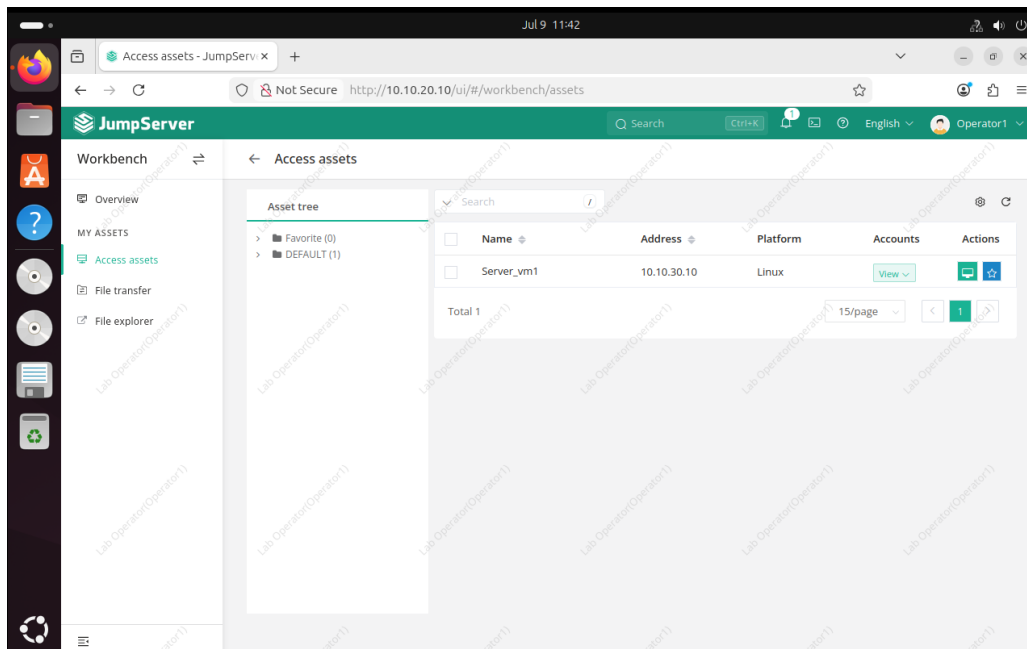


Figure 6.2: Operator1's workbench: access limited to Server_VM1

6.3 Establishing the SSH Session

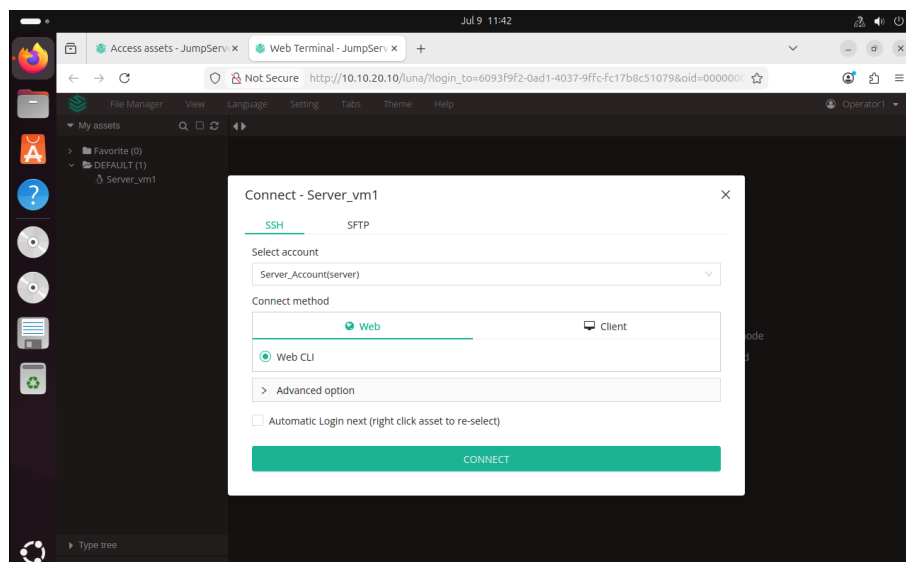


Figure 6.3: Connection window: account and method selection (Web CLI)

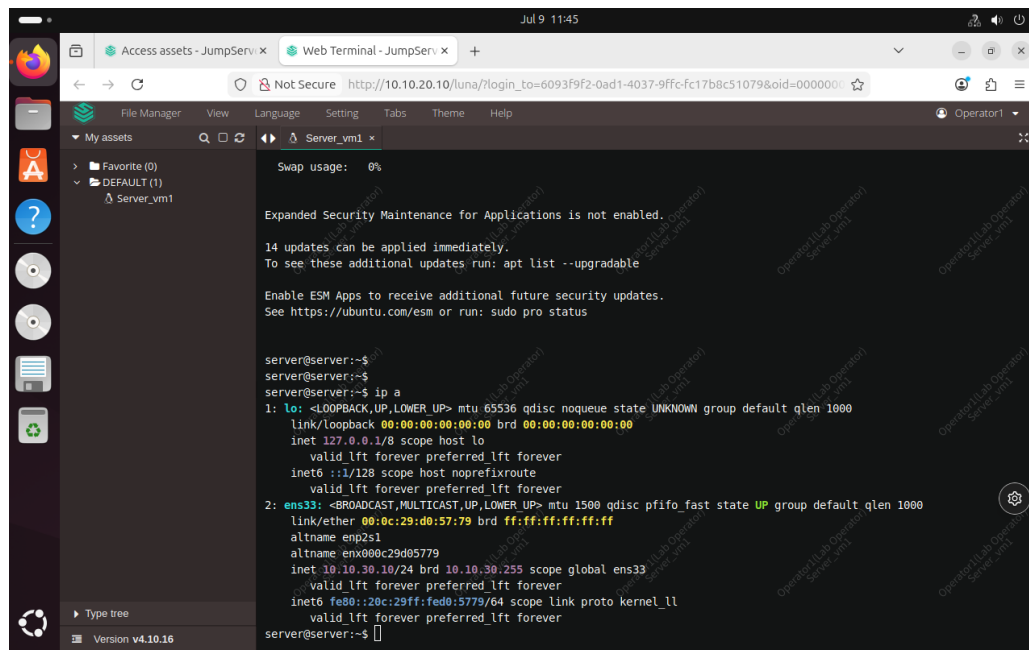


Figure 6.4: Active web terminal: SSH session established to Server_VM1 via JumpServer

7. Audit, Traceability, and Session Recording

7.1 Login Logs

The screenshot shows the JumpServer web interface. The top navigation bar includes the JumpServer logo, a search bar, and a user profile dropdown for 'Administrator'. The left sidebar contains various navigation options: Audits, Dashboard, Sessions (Asset sessions, Session commands, File transfer, Online devices), Activities (Login logs, Password change, Operate logs), Job Audits (Jobs, Executions), and Ticket Audits. The main content area is titled 'Login logs' and shows a table of login attempts for the date range 2026-07-02 to 2026-07-10. The table has columns for Username, Auth backend display, Login city, Reason display, Status, and Login date. There are six entries in total, with three successful logins and two failed logins. The bottom of the table shows 'Total 6' and a pagination control set to '15/page'.

☐	Username	Auth backend display	Login city	Reason display	Status	Login date
☐	Administrator...	Password	LAN	-	Success	07/09/2026 11:46:43
☐	Operator1(La...	Password	LAN	-	Success	07/09/2026 11:41:21
☐	Administrator...	Password	LAN	-	Success	07/09/2026 09:32:41
☐	admin	-	LAN	The username or pass...	Failed	07/09/2026 09:32:05
☐	Administrator...	Password	LAN	-	Success	07/08/2026 10:43:09
☐	admin	-	LAN	The username or pass...	Failed	07/08/2026 10:41:57

Total 6

15/page

Figure 7.1: JumpServer login logs

7.2 Operation Logs

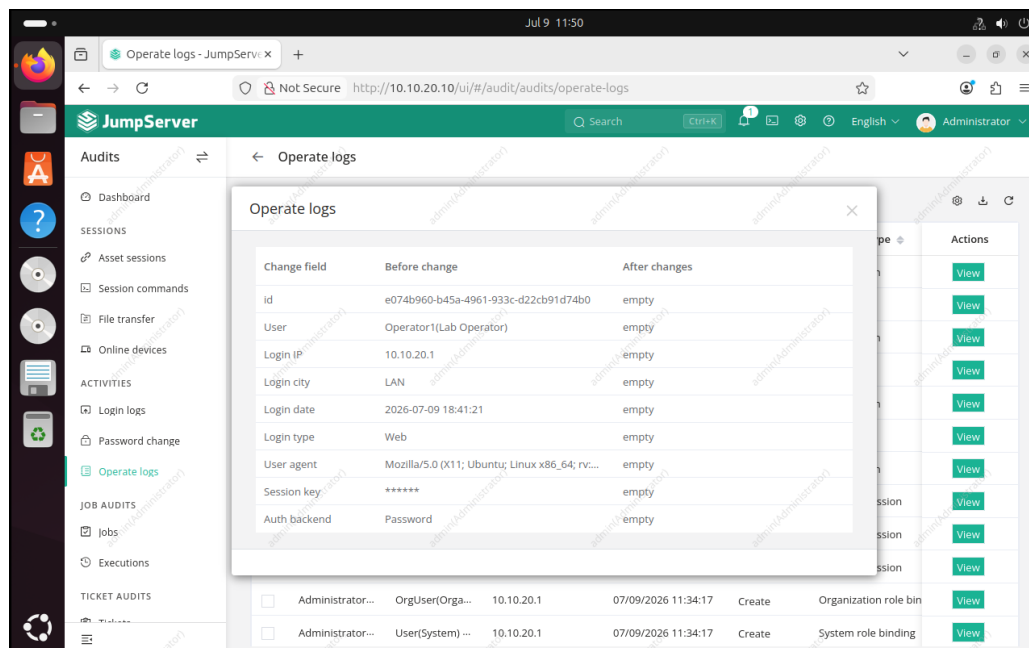


Figure 7.2: Detail of an operation log entry

7.3 Session Command Recording

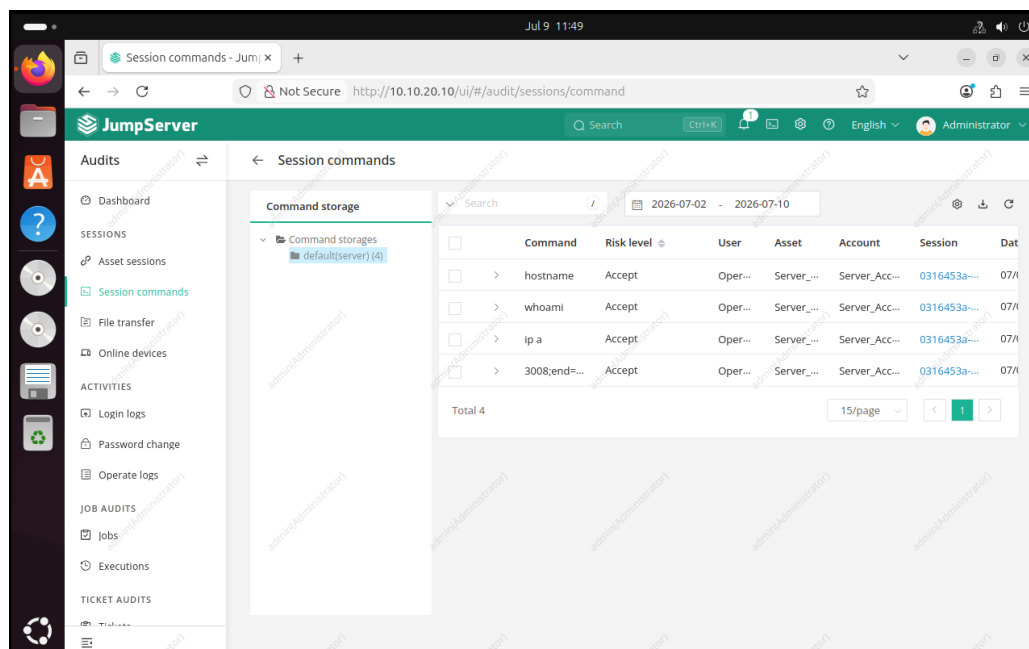


Figure 7.3: Commands entered during the session, with associated risk level

7.4 Replay of the Recorded Session

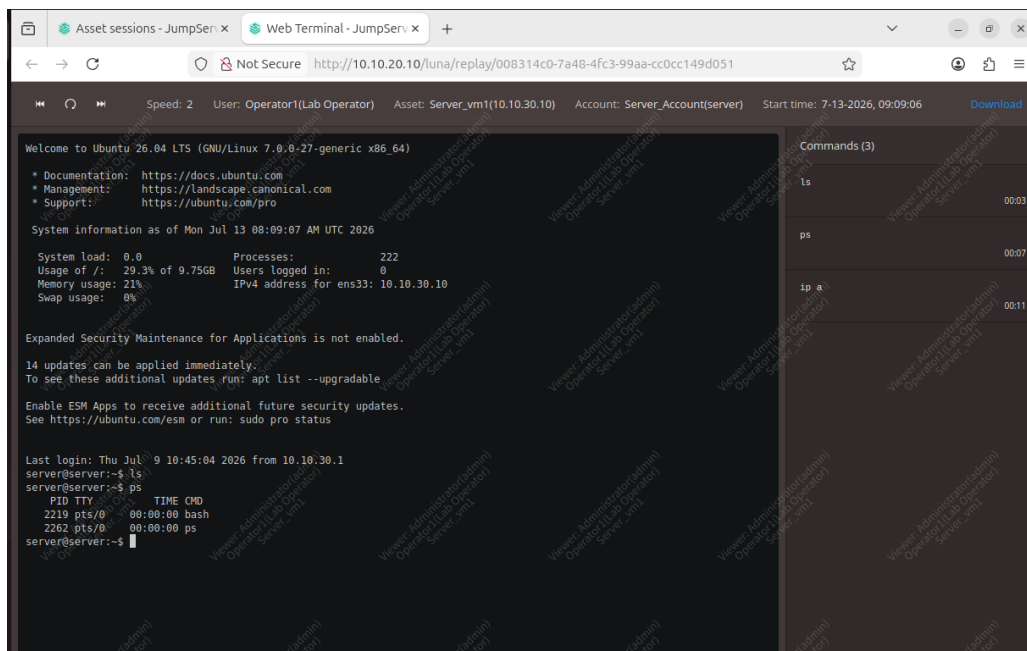


Figure 7.4: Replay of the recorded session: terminal, user, account used, and commands

8. Project Scope and Paths for Evolution

A security project is judged as much by what it protects as by how clearly its scope is defined. This chapter presents an in-depth analysis of the scope covered by the architecture, along with the evolution paths identified to extend its coverage – a deliberate exercise that builds on the work already completed rather than calling it into question.

8.1 Potential Reinforcement: Firewall Administration

The current architecture allows the AdminVM-1 workstation to access FortiGate’s configuration interface, in addition to its access to the broker. This configuration is common in small infrastructures, but a production infrastructure would typically separate the administration plane from the user access plane.

Proposed evolution: a dedicated, isolated management network (*out-of-band management*), differentiated administrative accounts with role-based access control (RBAC) on the firewall, multi-factor authentication on the super-administrator account, and systematic logging of every policy change. This separation would reinforce an already functional system, without altering its underlying architecture.

8.2 Potential Reinforcement: Resilience Against a Compromised Workstation

The network segmentation in place prevents any direct bypass of the broker – this is precisely its role, and it has been successfully verified. An additional layer can nonetheless be added to cover the scenario in which an attacker, in addition to gaining access to the AdminVM-1 workstation, also obtains Operator1’s active credentials: in that scenario, the broker would authenticate the attacker as a legitimate user.

Proposed evolution: multi-factor authentication (MFA) on JumpServer accounts, short session expiration, command filtering (*Command ACL*, already available in JumpServer and partially explored during this project), and correlation of logs with a detection tool (SIEM). Each of these measures builds directly on the auditing features already implemented and validated in Chapter 6.

8.3 Extension Toward a Complete Zero Trust Architecture

This project rigorously applies targeted Zero Trust principles: deny-by-default, explicit enforcement, least privilege, and separation of duties. Extending toward a full, organization-wide Zero Trust architecture would involve adding a centralized identity provider (IdP), continuous identity and context verification, endpoint posture control, a dynamic policy engine, and microsegmentation at the level of individual workloads. These components are natural extensions of the work completed, not corrections to be made to it.

8.4 Substitution of Wallix Bastion with JumpServer

The project was carried out with JumpServer due to the time required to obtain a Wallix Bastion evaluation license. The network architecture and firewall policies designed remain independent of the specific PAM product used: replacing JumpServer with Wallix Bastion would require no modification to the network segmentation or FortiGate policies – only the broker's internal configuration would need to be redone.

8.5 Summary of Identified Improvements

- restricting policies to specific address objects rather than entire zones, to anticipate the addition of multiple hosts within the same zone;
- enabling multi-factor authentication on JumpServer;
- implementing command filtering rules (Command ACL);
- integrating FortiGate and JumpServer logs into a correlation tool (SIEM) for anomaly detection;
- adding a second target server with a distinct access tier, to demonstrate finer-grained authorization.

9. Conclusion

This project made it possible to design, implement, and validate a privileged access gateway architecture combining strict network segmentation with session brokering. Every stage of the architecture was practically verified and documented: deny-by-default between zones, explicit authorization tested and then revoked, an effective connection through the broker without exposing the server's real password, and full session recording achieved.

This work was also an opportunity to develop a rigorous critical analysis of the architecture's scope – a skill that, alongside the technical implementation itself, is essential in information systems security.

This lab constitutes a solid, reproducible, and well-documented foundation, which can be extended through the integration of a commercial PAM product such as Wallix Bastion, the addition of detection mechanisms, or the reinforcement of authorization granularity.